

Vulnerability Scanning Tools & Techniques (CS0-003)

Introduction

Objective

Welcome to the **Vulnerability Scanning Tools & Techniques** practice lab. In this module, you will be provided with the instructions and devices needed to develop your hands-on skills.

Overview

Learning Outcomes:

In this module, you will complete the following exercises:

- Exercise 1 – Network Asset Detection Tools
- Exercise 2 – Detecting Network Vulnerabilities

After completing this module, you should be able to:

- Use NMAP to Detect Devices on the Network.
- Use Zenmap to Discover Devices on the Network.
- Scan Network Devices for Vulnerabilities with OWASP Zap.
- Detect Network Vulnerabilities using NMAP.
- Scan Network Devices with Nessus.
- Detect Vulnerabilities using Metasploit and NMAP.

Exam Objectives:

The following exam objectives are covered in this module:

2.1 Given a scenario, implement vulnerability scanning methods and concepts.

- Asset discovery

2.2 Given a scenario, analyze output from vulnerability assessment tools

- Tools

Exercise 1 – Network Asset Detection Tools

As a Cyber Security Specialist, a routine task that needs to be performed on the network is to detect the connected devices. These scans are essential to determine if any unauthorized or rogue devices are connected to the network.

The NMAP application is one of the well-known applications that can detect hosts on the network. Not only can it be used to detect hosts, but it can also be used also to detect device vulnerabilities.

In this exercise, different tools will be used to detect the connected devices and scan these devices for vulnerabilities.

Learning Outcomes

After completing this exercise, you should be able to:

- Use NMAP to Detect Devices on the Network
- Use Zenmap to Discover Devices on the Network

Your Devices

You will be using the following devices in this lab. Please power these on now.

- **ACIDC01** – Windows Server 2022 – Domain Controller
- **ACIDM01** – Windows Server 2022 – Domain Member Server
- **ACIWIN11** – Windows 11 – Domain Member Workstation
- **ACIALMA** – ALMA Linux Standalone Workstation
- **ACIKALI** – Kali Linux Standalone Workstation

Task 1 – Using NMAP to Detect Devices on the Network

The NMAP application can be used to detect the connected devices on the network. Additional functionality of the nmap tool also includes the ability to determine open ports and services running on the devices.

The NMAP application can detect possible vulnerabilities by a Cyber Security Analyst before they are exploited.

In this task, the NMAP application will be used to identify the connected devices and determine which ports and services are running on these devices.

1

Click the **Start** button.



2 **Connect** to **ACIDM01**.

Click **Send Ctrl+Alt+Delete button** on the top of the screen.

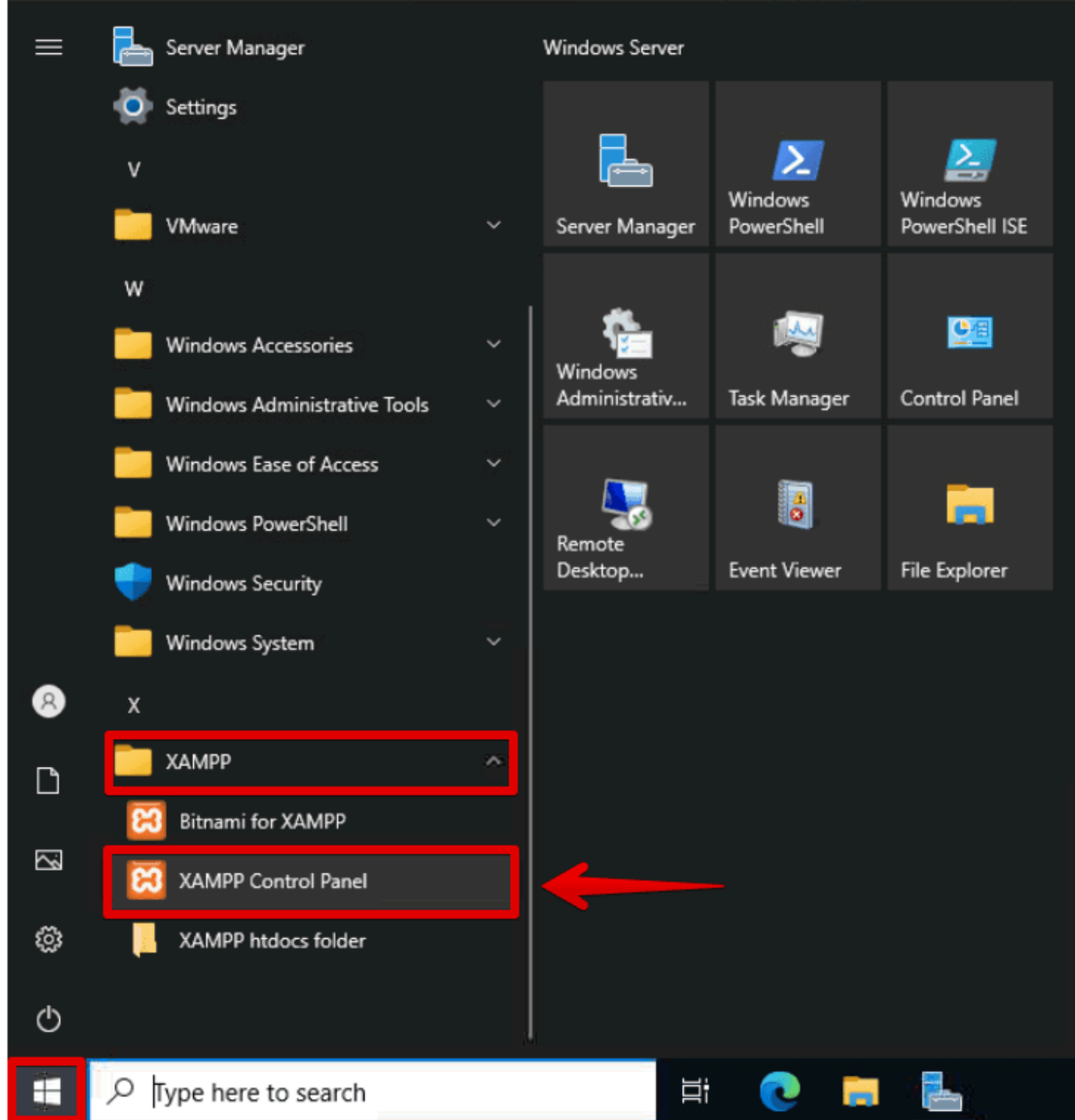
Username: **ACIPLAB\Administrator**

Password: **Passw0rd**



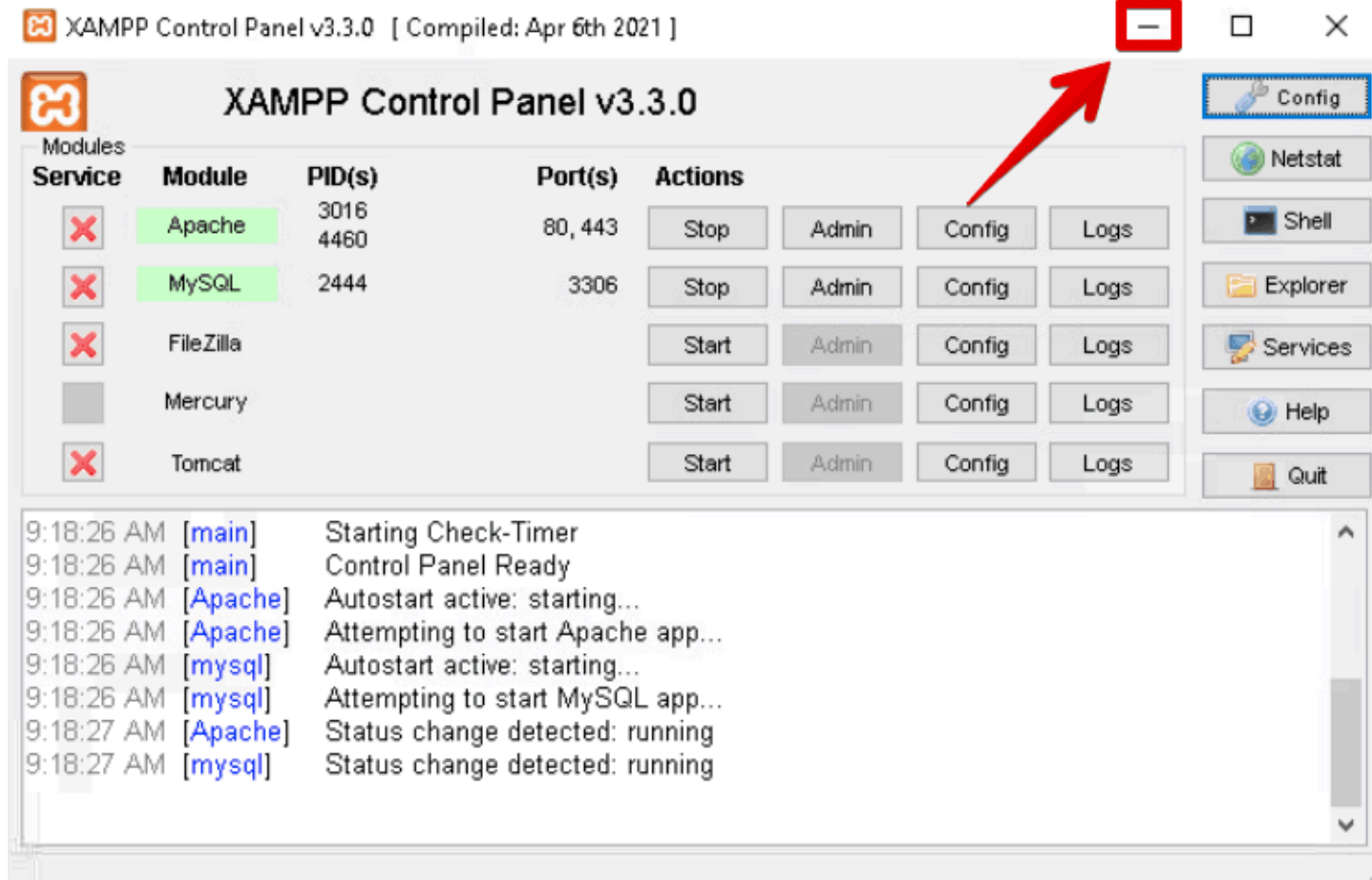
Note: Before logging in, use the **eye (show password)** icon to confirm the password.
If the letter **"P"** does not appear uppercase, please use **Shift + P**.

Click **Start** and **select** **XAMPP > XAMPP Control Panel**.



3

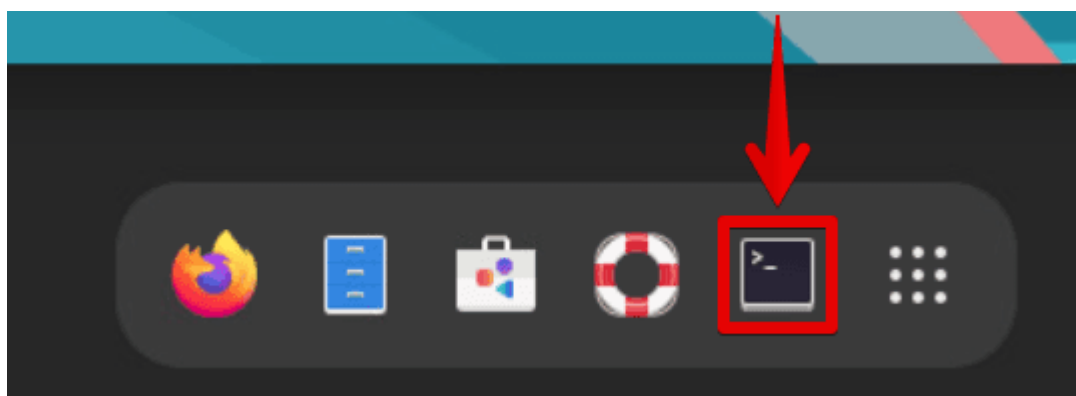
Minimize the XAMPP Control Panel window.



Note: The XAMPP application must be started to ensure the device's Apache and MSQL services are started. When opening the application, the services will start automatically. A vulnerable website has been deployed, which will be used for the next steps.

4

Connect to **ACIALMA** from the **Activities menu** and **select Terminal**.



5

In the **aciadmin@localhost:~** window, **type** the **following** and **press Enter**:

```
sudo nmap 192.168.0.0/24
```

Enter the **following password** and **press Enter**:

```
aciadmin@localhost:~$ sudo nmap 192.168.0.0/24
[sudo] password for aciadmin: Passw0rd
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:20 EDT
Nmap scan report for 192.168.0.1
Host is up (0.00022s latency).
Not shown: 988 filtered ports
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
MAC Address: 00:15:5D:5E:43:93 (Microsoft)

Nmap scan report for 192.168.0.2
Host is up (0.00023s latency).
Not shown: 994 filtered ports
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
2179/tcp  open  vmrdp
3389/tcp  open  ms-wbt-server
MAC Address: 00:15:5D:5E:43:94 (Microsoft)

Nmap scan report for 192.168.0.3
Host is up (0.00033s latency).
Not shown: 998 filtered ports
PORT      STATE SERVICE
135/tcp   open  msrpc
```



Note: The nmap command can be executed without any parameters and scans for all the available hosts in the specified IP range. From the command output, it can be determined that there are six detected hosts with their correlating IP addresses. This information can be used to determine if the devices are legitimate.

```
sudo nmap 192.168.0.1 -O
```

```
[aciadmin@localhost ~]$ sudo nmap 192.168.0.1 -O
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:22 EDT
Nmap scan report for 192.168.0.1
Host is up (0.00021s latency).
Not shown: 988 filtered ports
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
MAC Address: 00:15:5D:5E:43:93 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2016|10|2012|Vista (93%)
OS CPE: cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_server_2012:r2
cpe:/o:microsoft:windows_vista::sp1:home_premium
Aggressive OS guesses: Microsoft Windows Server 2016 (93%), Microsoft Windows 10 (89%), Microsoft Windows Server
2012 or Windows Server 2012 R2 (87%), Microsoft Windows Vista Home Premium SP1 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.02 seconds
[aciadmin@localhost ~]$
```



Note: The nmap command can be executed with different parameters. The **-O** parameter detects the Operating system of the specified IP address. Note that there are specific percentages on how accurate the results are. From the output, it can be determined that it is a Windows Server operating system running on the host.

7 In the **aciadmin@localhost:~** window, **type** the following and **press Enter**:

```
sudo nmap 192.168.0.5 -O
```

```
[aciadmin@localhost ~]$ sudo nmap 192.168.0.5 -O
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:24 EDT
Nmap scan report for 192.168.0.5
Host is up (0.00015s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 00:15:5D:5E:43:95 (Microsoft)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.6
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.58 seconds
[aciadmin@localhost ~]$
```

8

In the `aciadmin@localhost:~` window, **type** the following and **press** Enter:

```
nmap 192.168.0.2 -sV
```

```
[aciadmin@localhost ~]$ nmap 192.168.0.2 -sV
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:25 EDT
Nmap scan report for 192.168.0.2
Host is up (0.00081s latency).
Not shown: 994 filtered ports
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/8.2.0)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
2179/tcp  open  vmrpd?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.16 seconds
[aciadmin@localhost ~]$
```



Note: Executing the nmap command with the `-sV` parameters determines the specific services and versions running on the device. A Cyber Security Specialist will analyze the results and determine if some vulnerable ports or services are running on the device. From the output, port 80 is open, and a version of the Apache httpd 2.4.54 service is running on the device. Port 80 transmits network traffic unencrypted and is a possible point of exploitation.

9

In the `aciadmin@localhost:~` window, **type** the following and **press** Enter:

```
nmap 192.168.0.4 -sV
```

```
[aciadmin@localhost ~]$ nmap 192.168.0.4 -sV
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:27 EDT
Nmap scan report for 192.168.0.4
Host is up (0.00016s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh         OpenSSH 8.7 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.53 ((AlmaLinux))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.36 seconds
[aciadmin@localhost ~]$
```



Note: The command displays the services and version running on the Linux device.

10

In the `aciadmin@localhost:~` window, **type** the following and **press** Enter:

```
nmap 192.168.0.3 -A
```

```
[aciadmin@localhost ~]$ nmap 192.168.0.3 -A
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:32 EDT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.29 seconds
[aciadmin@localhost ~]$
```



Note: Executing the command with the **-A parameter** displays more detailed information about the detected it. This includes the domain the device is joined to, the device name and the version of the operating system. In addition, the command also displays how the device was connected to the network using a traceroute command. The same results will be displayed when the following parameters are specified: **-O -sV**, using the **-A parameter** is a combination of these parameters.

11

In the **aciadmin@localhost:~** window, **type** the **following** and **press Enter**:

```
nmap 192.168.0.5 -A
```

```
[aciadmin@localhost ~]$ nmap 192.168.0.5 -A
Starting Nmap 7.91 ( https://nmap.org ) at 2024-05-02 12:33 EDT
Nmap scan report for 192.168.0.5
Host is up (0.00040s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2 (protocol 2.0)
| ssh-hostkey:
|   256 6b:d8:03:9b:91:2c:4c:d9:57:84:b7:0e:fb:21:6c:15 (ECDSA)
|_  256 2b:bb:c9:46:08:8b:f4:47:02:52:a9:1d:8a:0d:de:56 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.54 seconds
[aciadmin@localhost ~]$
```

Task 2 – Using Zenmap to Discover Devices on the Network

Over the years, the nmap application has evolved and can be used on a Windows operating system using a Graphical User Interface (GUI).

In this task, the Zenmap application will be used to detect the available hosts on the network.

1

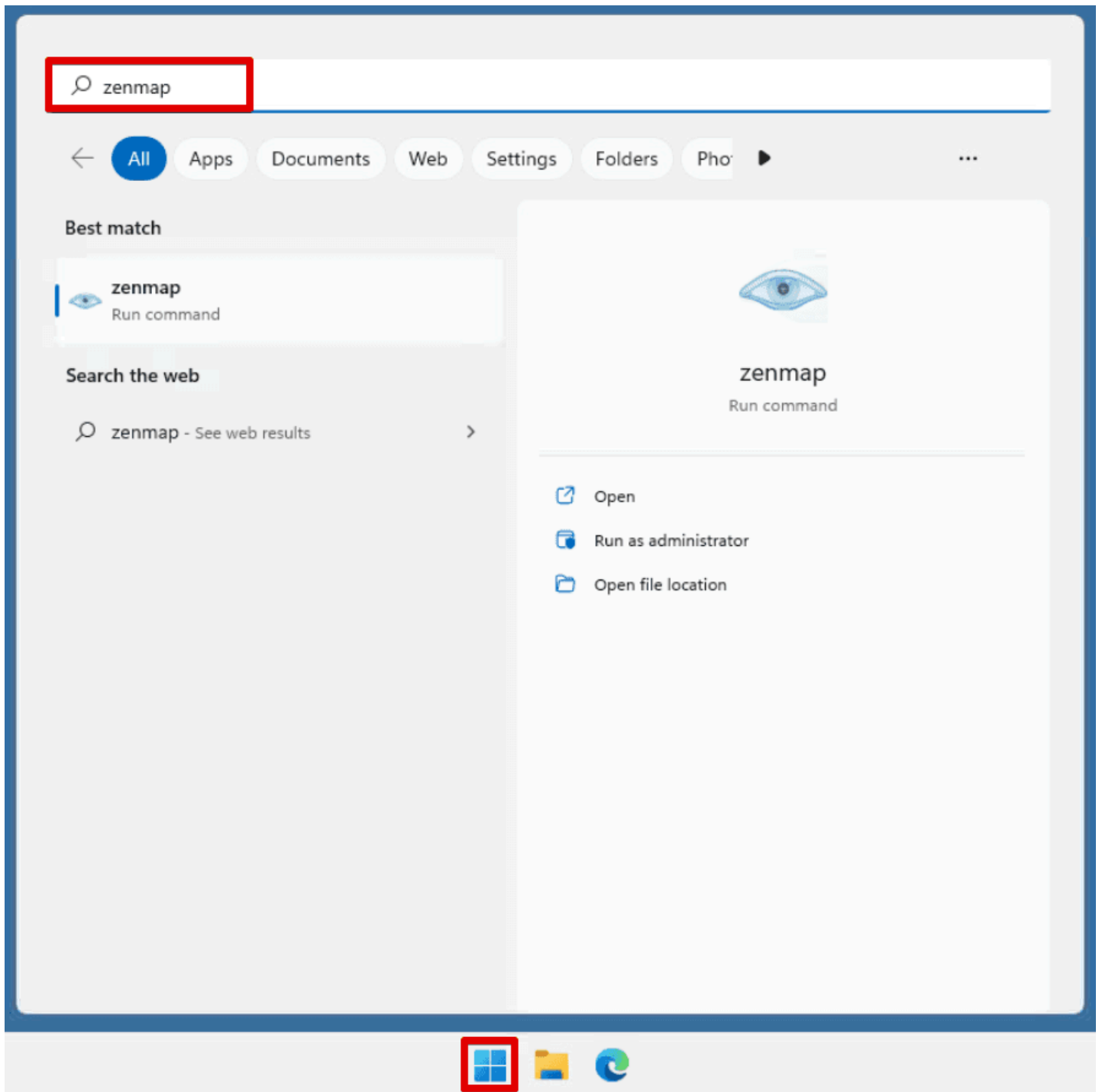
Connect to **ACIWIN11**,

Click the **Send Ctrl+Alt+Delete button** on the top of the screen.

Username: **ACIPLAB\Administrator**

Password: `Passw0rd`

Click **Start**, type `zenmap`, and **press** **Enter**.



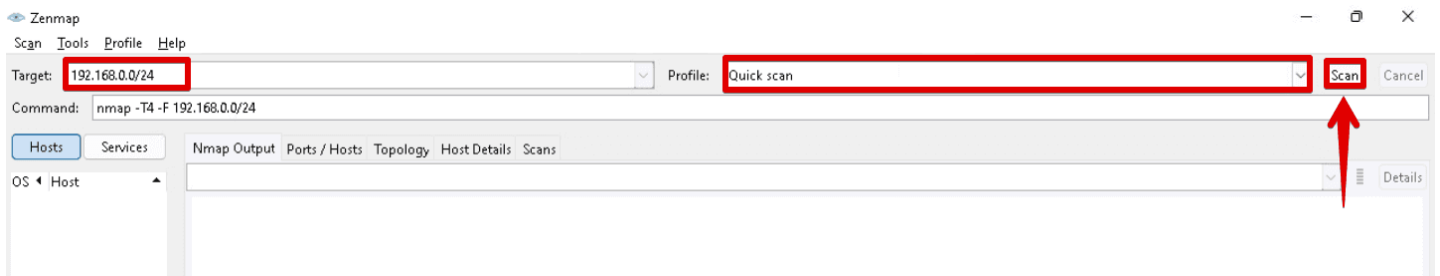
2

In the **Target** field, **enter** the following:

`192.168.0.0/24`

In the **Profile** drop-down menu, **select** **Quick scan**.

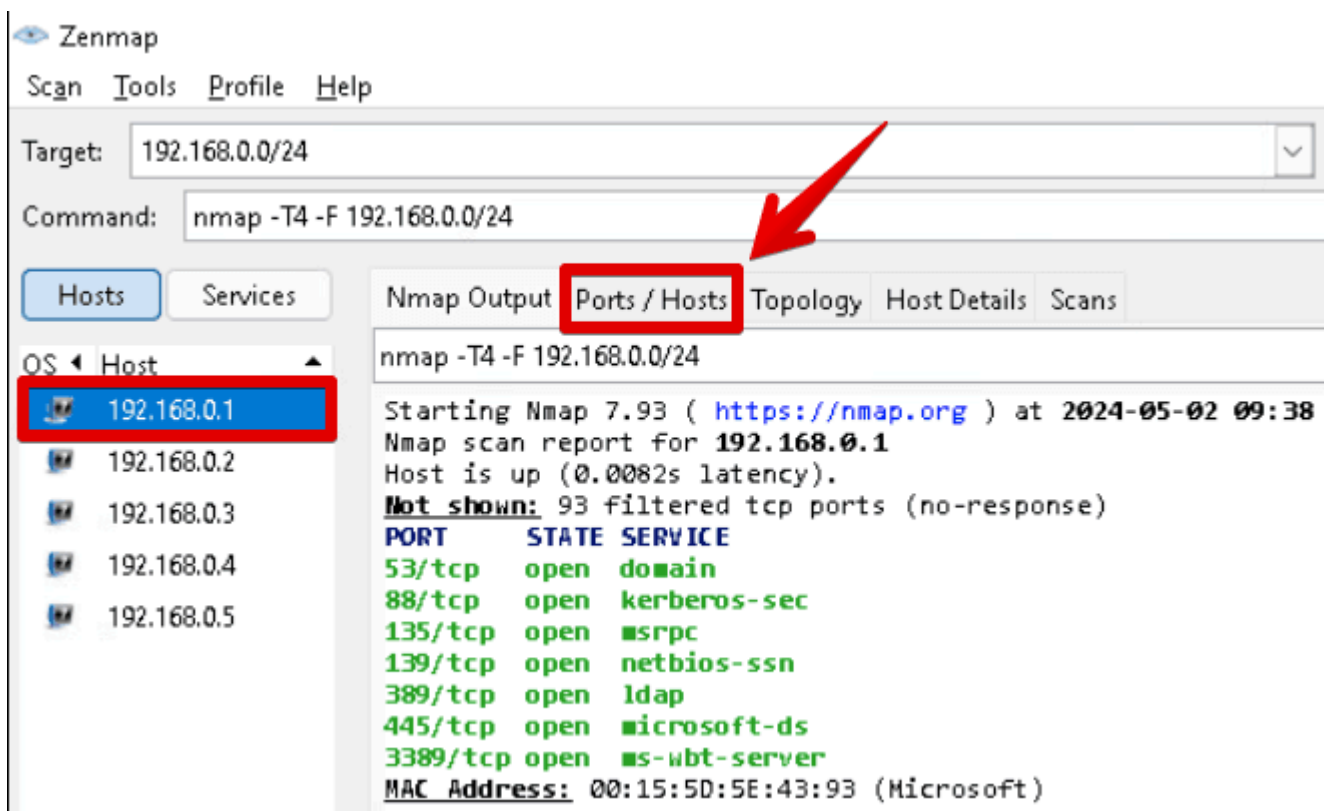
Click Scan.



Note: The Zenmap application is a Graphical User Interface (GUI) version of the nmap application and can be used on a Windows operating system. Take note that the Command field changes when changing the Profile drop-down menu. After the scan has been completed, the discovered hosts on the network are displayed. These results can be compared with the results from Task 1.

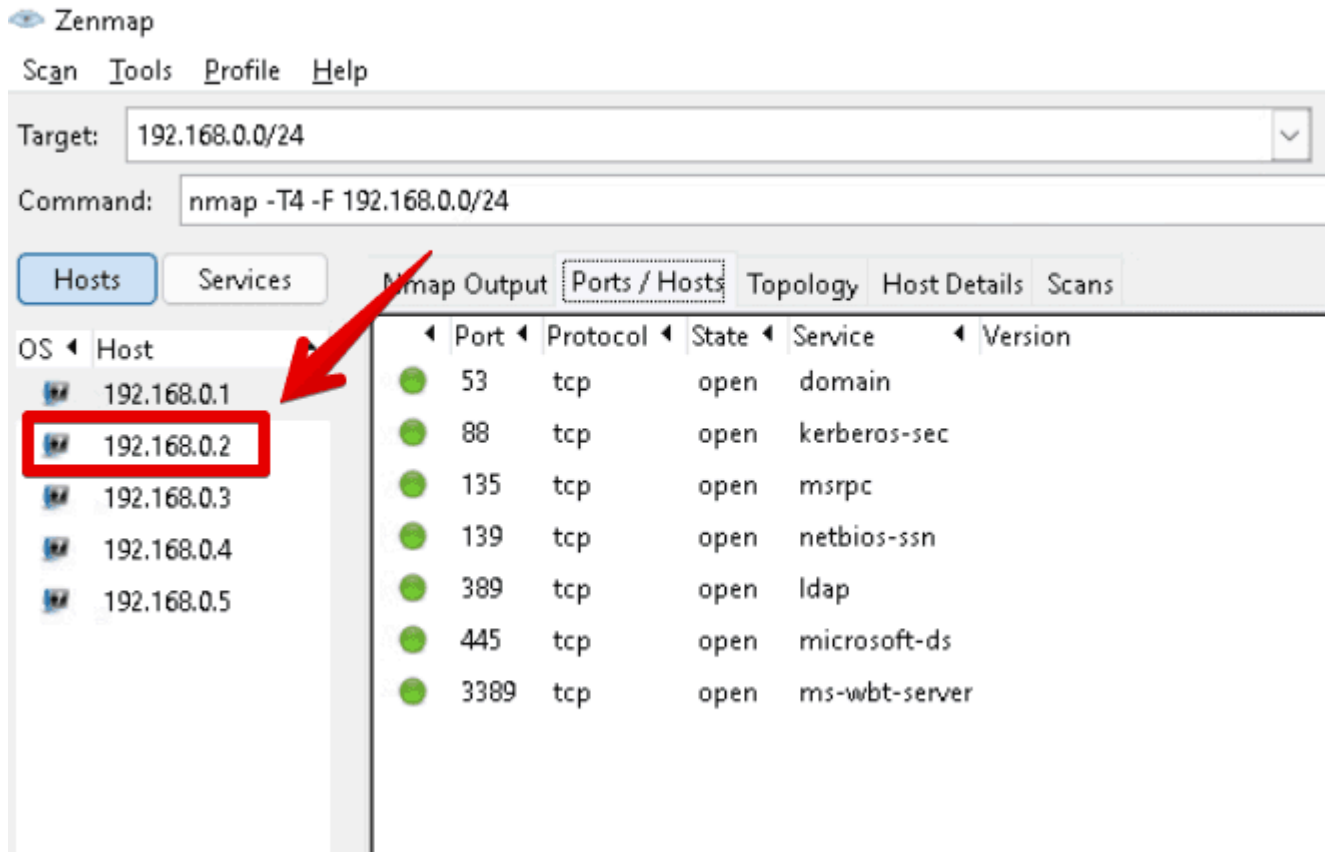
3

Select **192.168.0.1** in the **Hosts** pane and **click** the **Ports/Hosts** tab.



4

Click **192.168.0.2** in the **Hosts** pane.



Note: The network's open ports for the detected hosts are displayed in the Zenmap application.

5

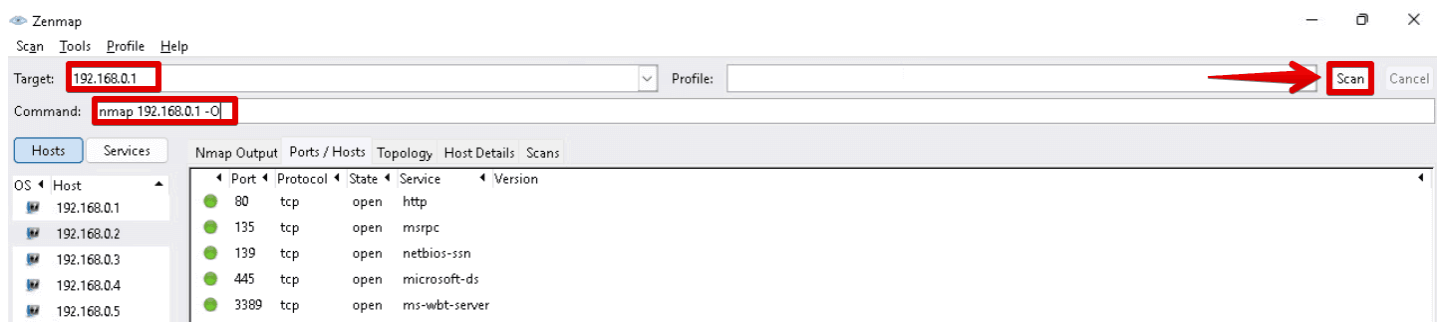
In the **Target** field, **enter** the following:

192.168.0.1

Change the **command** field to the following:

nmap 192.168.0.1 -O

Click **Scan**.



6

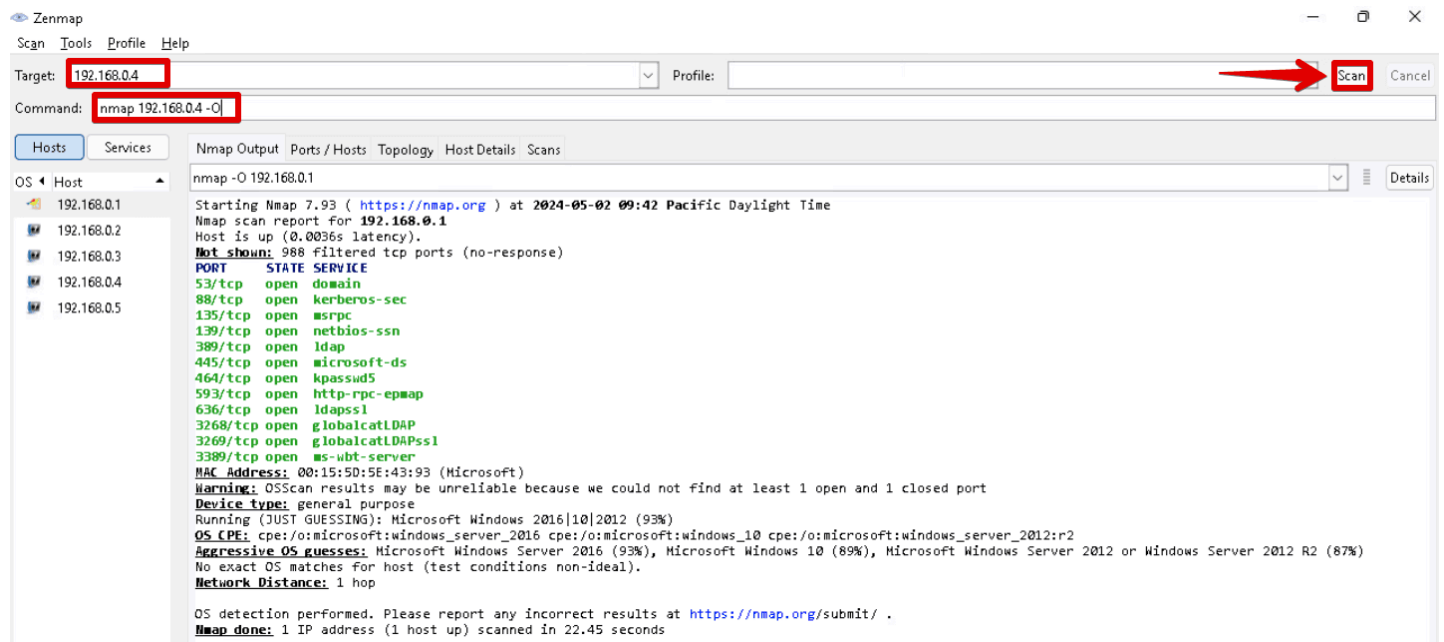
In the **Target** field, **enter** the following:

192.168.0.4

Change the command field to the following:

```
nmap 192.168.0.4 -O
```

Click Scan.



Note: The Zenmap application can detect the operating systems of the hosts on the network. Note that the same command was used in the previous task when executed in the bash shell.

7

In the Target field, enter the following:

```
192.168.0.2
```

Change the command field to the following:

```
nmap 192.168.0.2 -A
```

Click Scan.



8

In the **Target** field, **enter** the following:

192.168.0.5

Change the **command** field to the following:

nmap 192.168.0.5 -A

Click **Scan**.

The screenshot shows the Zenmap application window. The **Target** field is set to `192.168.0.5` and the **Command** field is set to `nmap 192.168.0.5 -A`. A red arrow points to the **Scan** button. The **Hosts** tab is selected, showing a list of hosts. The **Host** 192.168.0.2 is selected, and the **Nmap Output** tab is active, displaying the scan results for 192.168.0.2.

```

nmap -A 192.168.0.2
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/8.2.0)
|_ http-title: Welcome to XAMPP
|_ Requested resource was http://192.168.0.2/dashboard/
|_ http-server-header: Apache/2.4.54 (Win64) OpenSSL/1.1.1p PHP/8.2.0
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
2179/tcp   open  vnc?
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
rdp-ntlm-info:
  Target_Name: ACIPLAB
  NetBIOS_Domain_Name: ACIPLAB
  NetBIOS_Computer_Name: ACIDM01
  DNS_Domain_Name: ACIPLAB.COM
  DNS_Computer_Name: ACIDM01.ACIPLAB.COM
  DNS_Tree_Name: ACIPLAB.COM
  Product_Version: 10.0.20348
_ System_Time: 2024-05-02T16:45:36+00:00
_ ssl-date: 2024-05-02T16:46:16+00:00; 0s from scanner time.
_ ssl-cert: Subject: commonName=ACIDM01.ACIPLAB.COM
Not valid before: 2024-02-13T23:08:29
Not valid after: 2024-08-14T23:08:29
MAC Address: 00:15:5D:5E:43:94 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2016|10|2012|Vista (93%)
OS CPE: cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_server_2012:r2 cpe:/o:microsoft:windows_vista::spl:home_premium
Aggressive OS guesses: Microsoft Windows Server 2016 (93%), Microsoft Windows 10 (89%), Microsoft Windows Server 2012 or Windows Server 2012 R2 (87%), Microsoft Windows Vista Home Premium SP1 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
_ smb2-time:
  date: 2024-05-02T16:45:36
_ start_date: N/A
_ nbstat: NetBIOS name: ACIDM01, NetBIOS user: <unknown>, NetBIOS MAC: 00155d5e4394 (Microsoft)
  smb2-security-mode:
    311:
      Message signing enabled but not required

TRACEROUTE
HOP RTT ADDRESS
1 0.08 ms 192.168.0.2

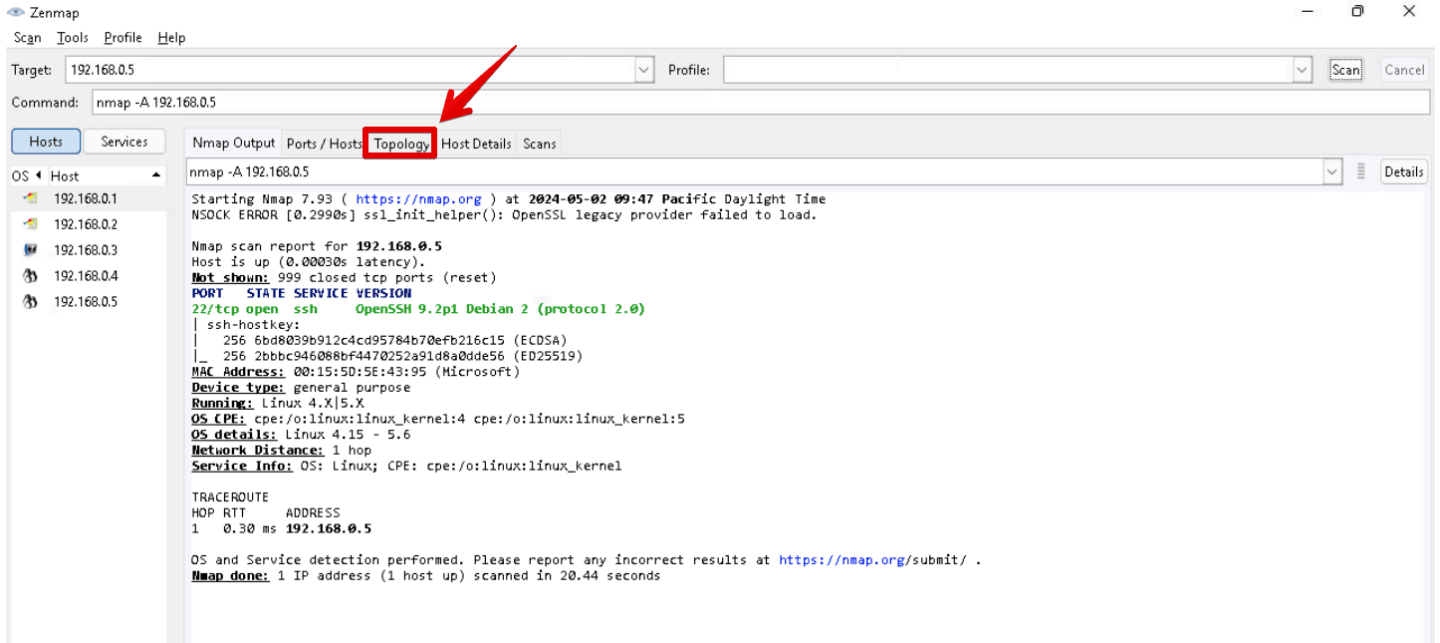
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 84.85 seconds
  
```



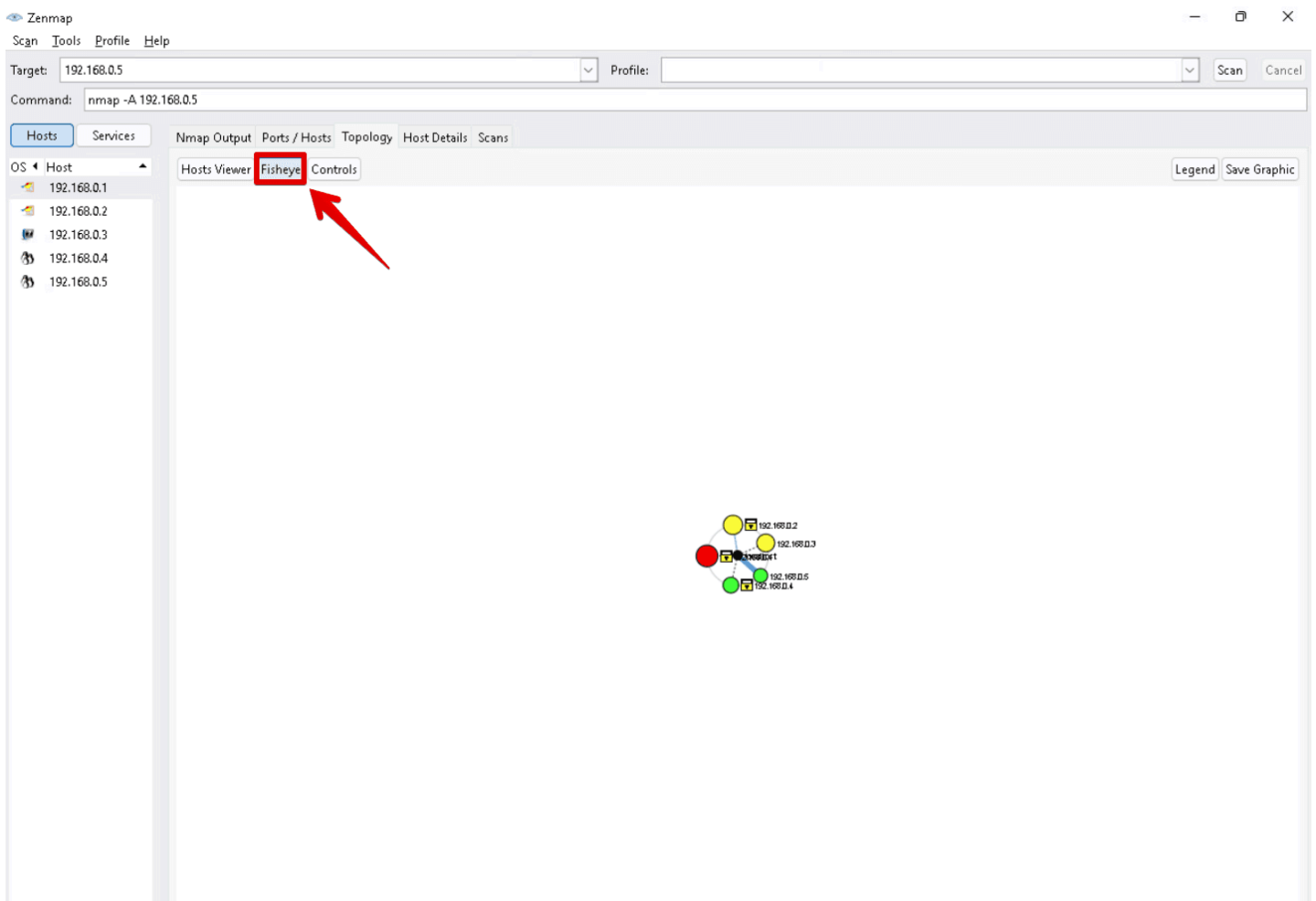
Note: More details of the detected host are displayed using the **-A** parameter. The results can be compared to the previous task to verify that the results are the same.

9

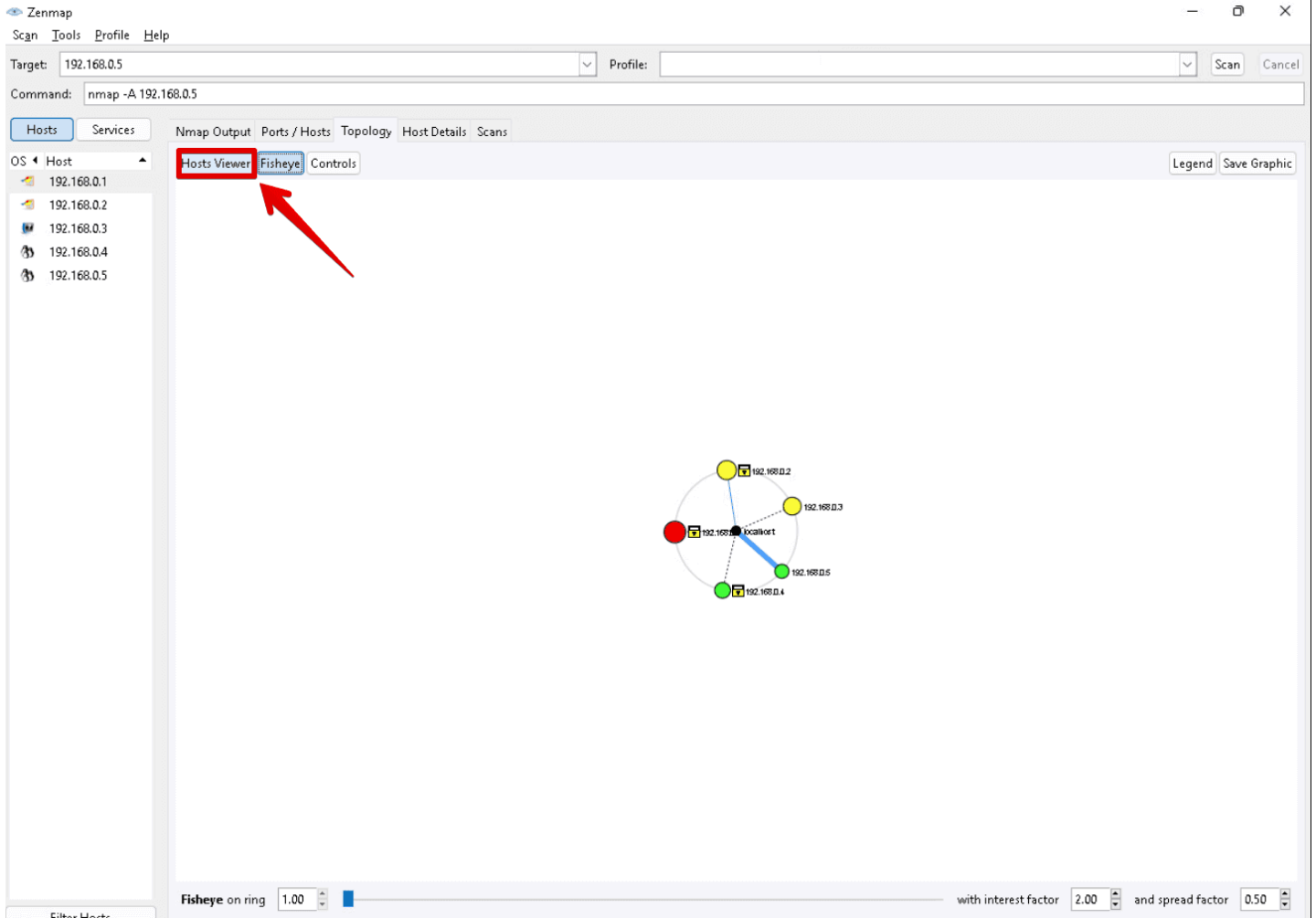
Click the **Topology** tab in the Zenmap application.



10 Click the **Fisheye** tab in the **Topology** pane.

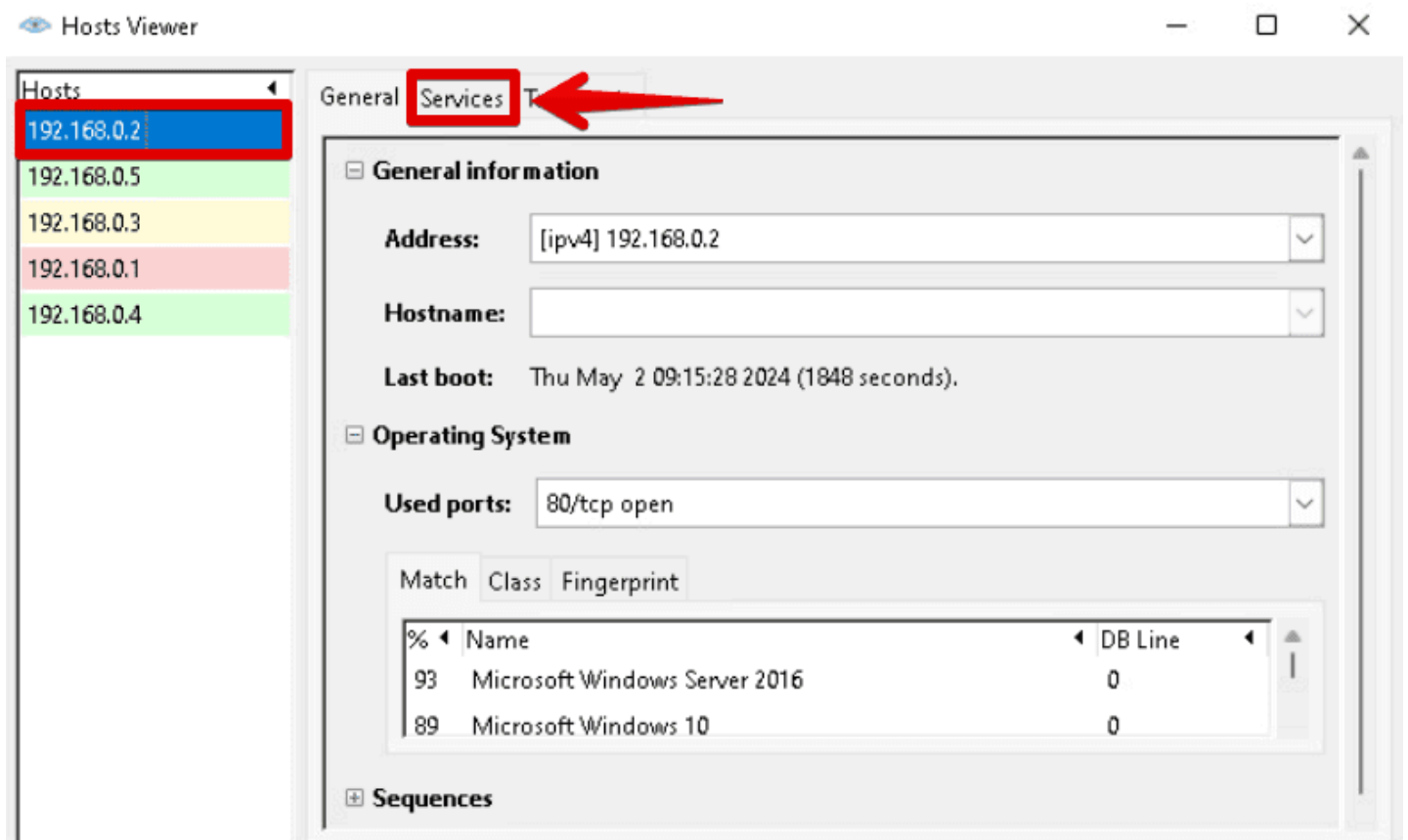


11 Select the **Host Viewer** tab in the **Topology** pane.



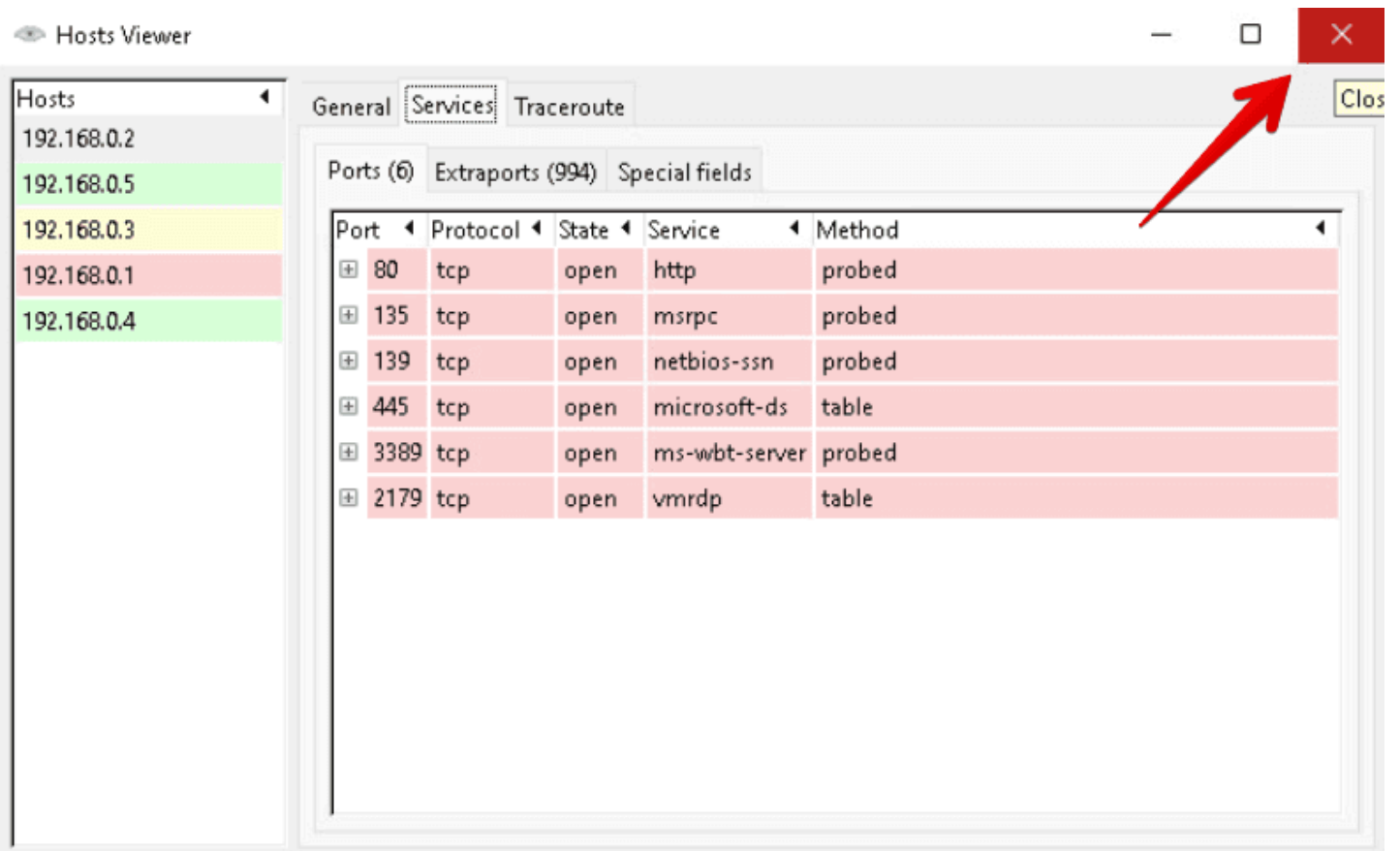
12

Ensure 192.168.0.2 is selected and click the Services tab.



Note: The Host Viewer tab gives more details of the detected hosts on the network.

Close the **Host Viewer window** after viewing the information available.

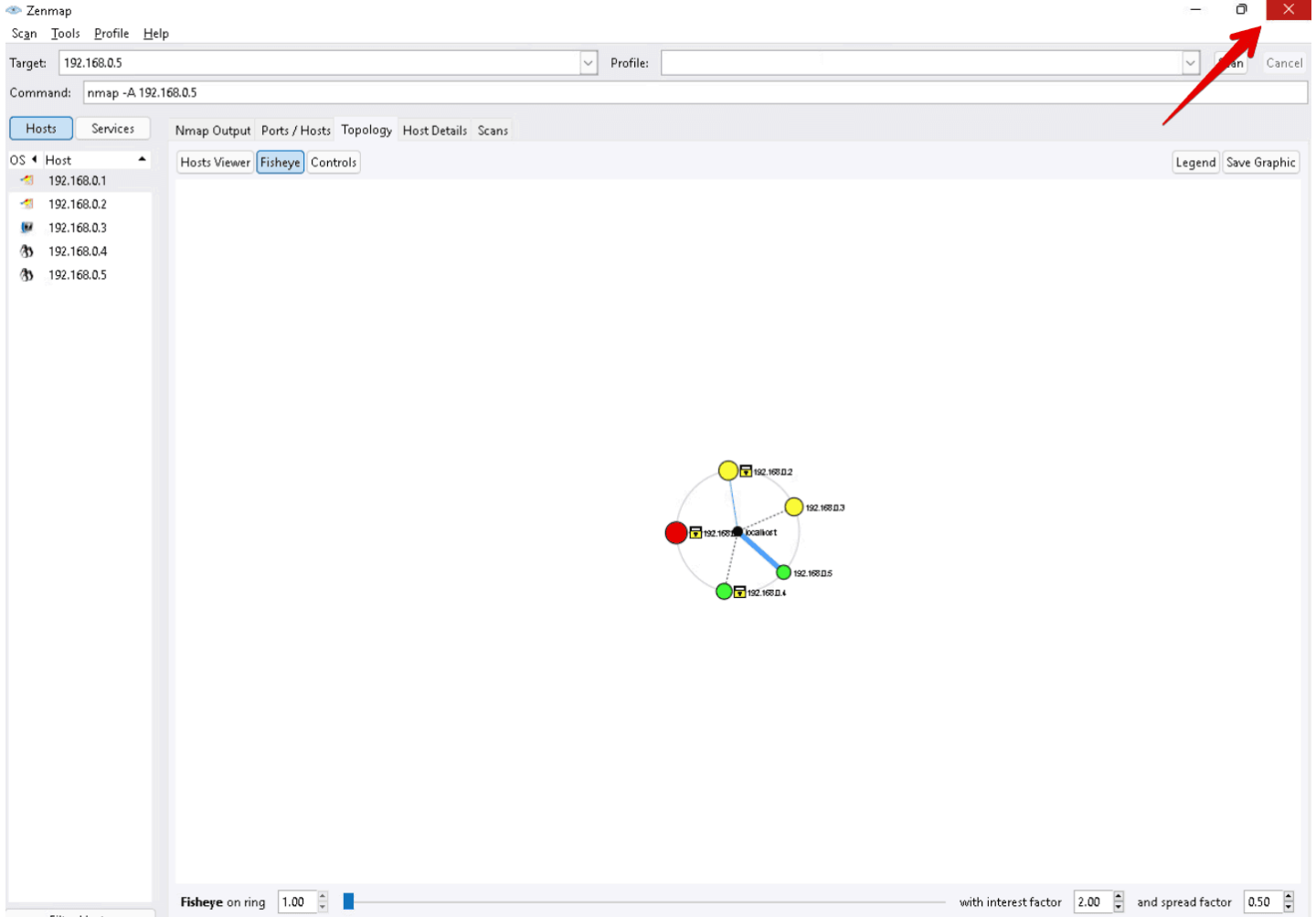


Note: The open ports and services running in the host are displayed. a Cyber Security Specialist can use these results to detect and remediate a device's vulnerabilities accordingly.

14

Close the Zenmap application.

When prompted, **click** Close anyway.



Exercise 2 – Detecting Network Vulnerabilities

As a Cyber Security Specialist, devices on the network must be scanned to determine any possible vulnerabilities. These vulnerabilities need to be remediated to prevent possible exploits of the devices.

In this exercise, devices will be scanned for vulnerabilities utilizing different applications.

Learning Outcomes

After completing this exercise, you should be able to:

- Scan Network Devices for Vulnerabilities with OWASP Zap
- Detect Network Vulnerabilities using NMAP
- Scan Network Devices with Nessus
- Detect Vulnerabilities using Metasploit and NMAP

Your Devices

You will be using the following devices in this lab. Please power these on now.

- **ACIDC01** – Windows Server 2022 – Domain Controller
- **ACIDM01** – Windows Server 2022 – Domain Member Server
- **ACIWIN11** – Windows 11 – Domain Member Workstation

- **ACIALMA** – ALMA Linux Standalone Workstation
- **ACIKALI** – Kali Linux Standalone Workstation

Task 1 – Scan Network Devices for Vulnerabilities with OWASP Zap

A Cyber Security Specialist needs to routinely scan the network devices to detect possible vulnerabilities. If any vulnerabilities are detected, it needs to be remediated to prevent the exploitation of the device.

In this task, the network device will be scanned for possible vulnerabilities with the OWASP ZAP application.

1

Connect to **ACIWIN11**,

Click **Send Ctrl+Alt+Delete** button on the top of the screen.

Sign-in with the **following credentials**:

Username: **ACIPLAB\Administrator**

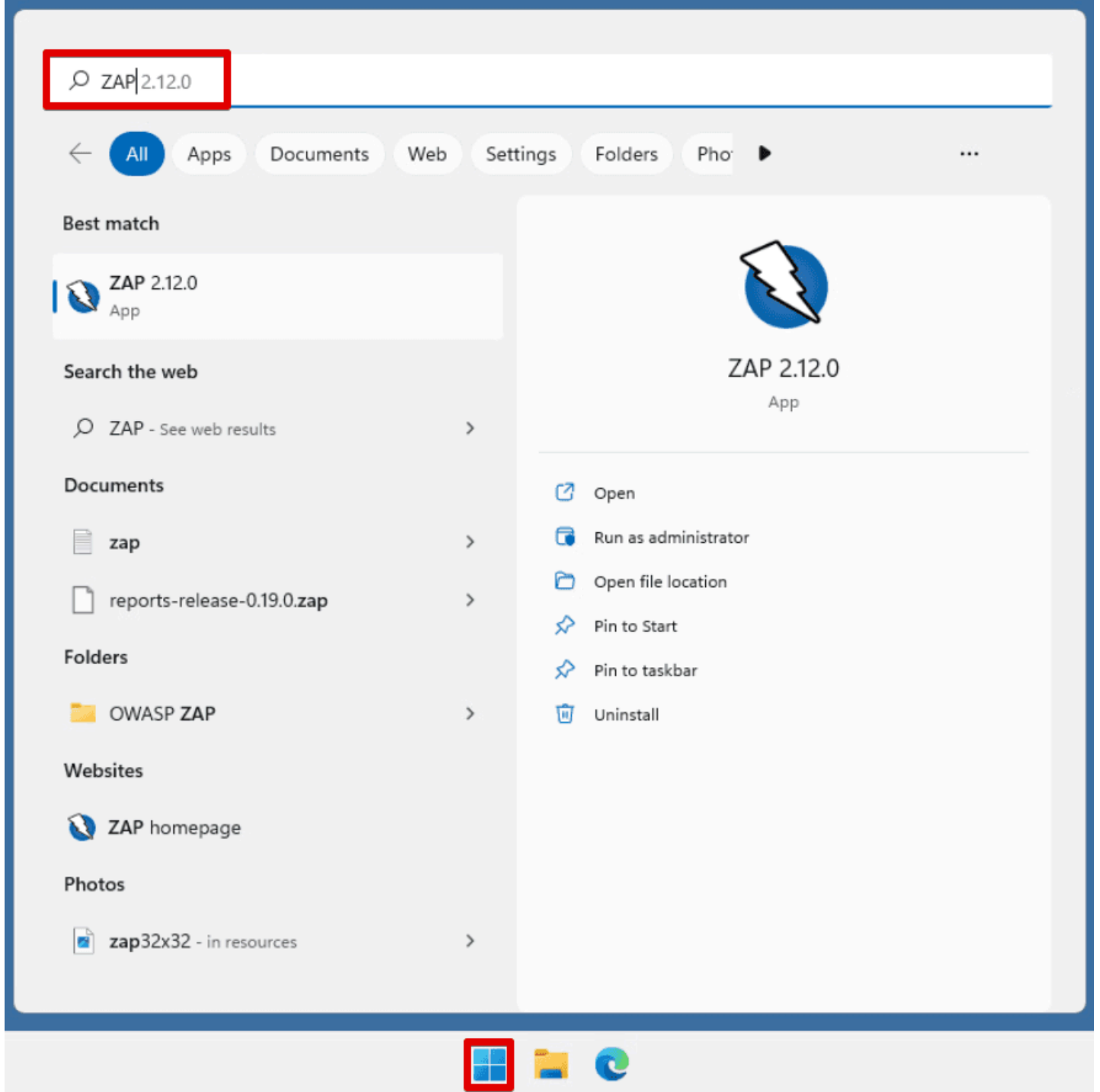
Password: **Passw0rd**



Note: Before logging in, use the **eye (show password)** icon to confirm the password. If the letter **"P"** does not appear uppercase, please use **Shift + P**.

2

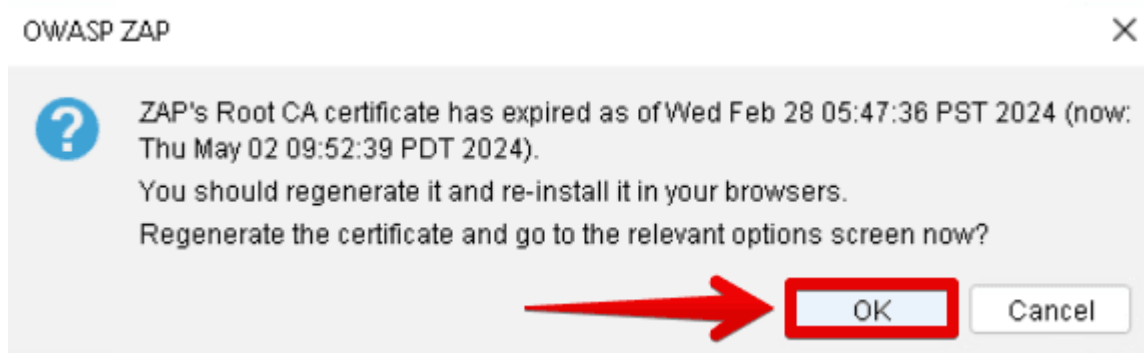
Click Start, type ZAP, and press Enter.



Note: Ensure that the **XAMPP** application has been started on **ACIDM01**.

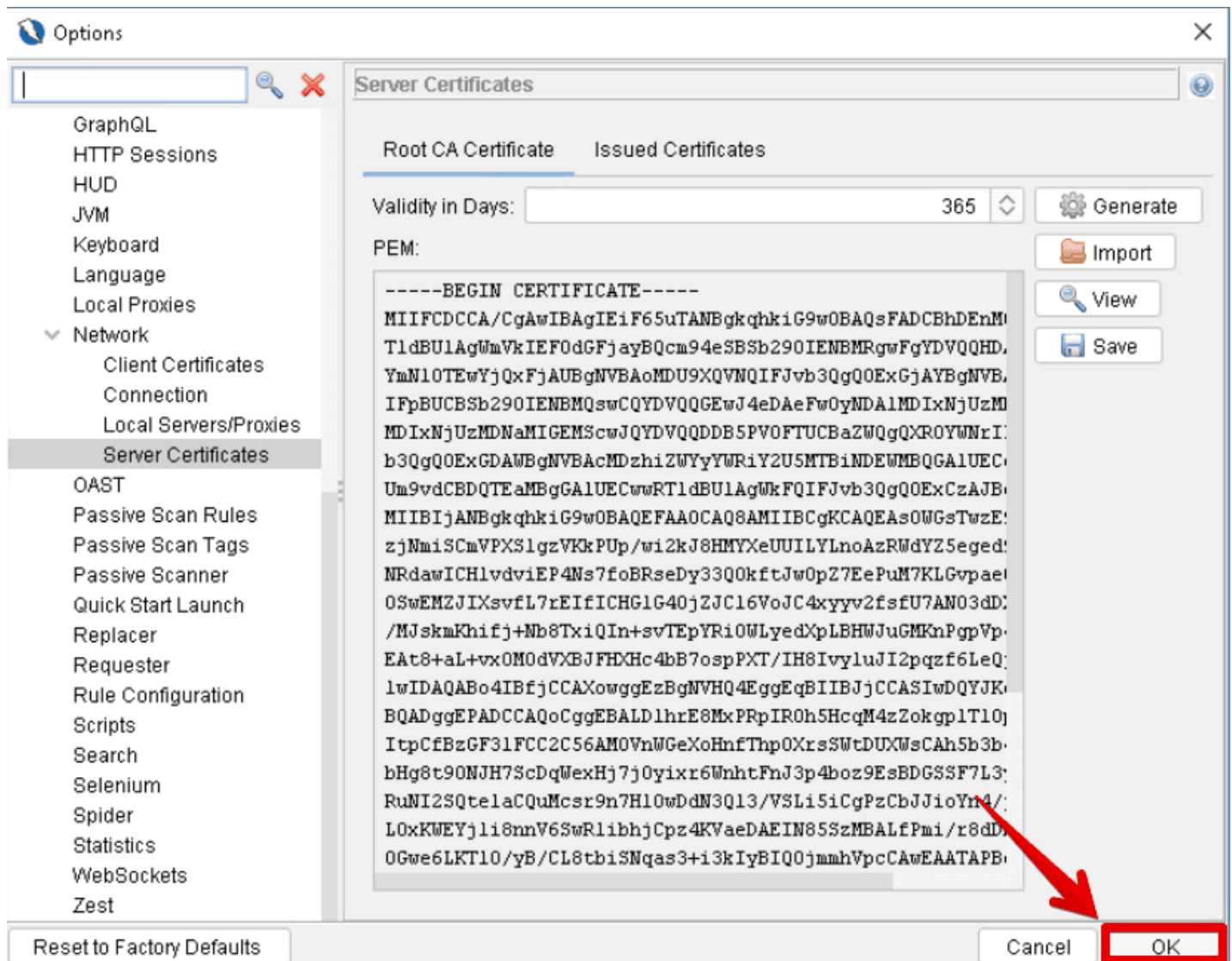
3

Click **OK** on the ZAP's Root CA dialog box.



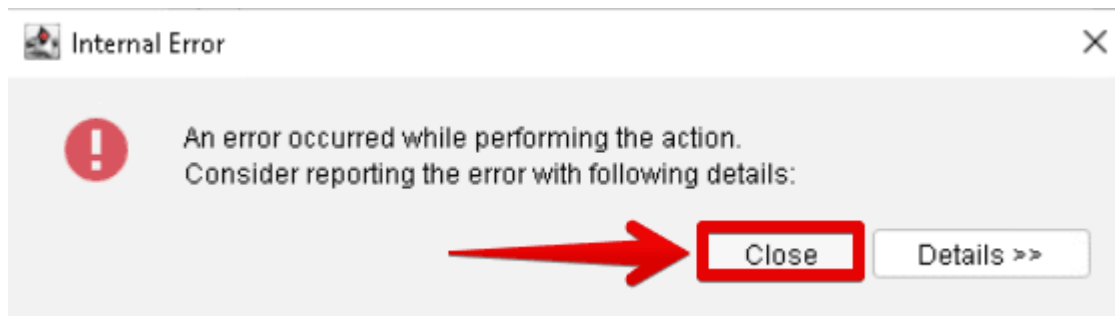
4

Click **OK** on the Options Window.



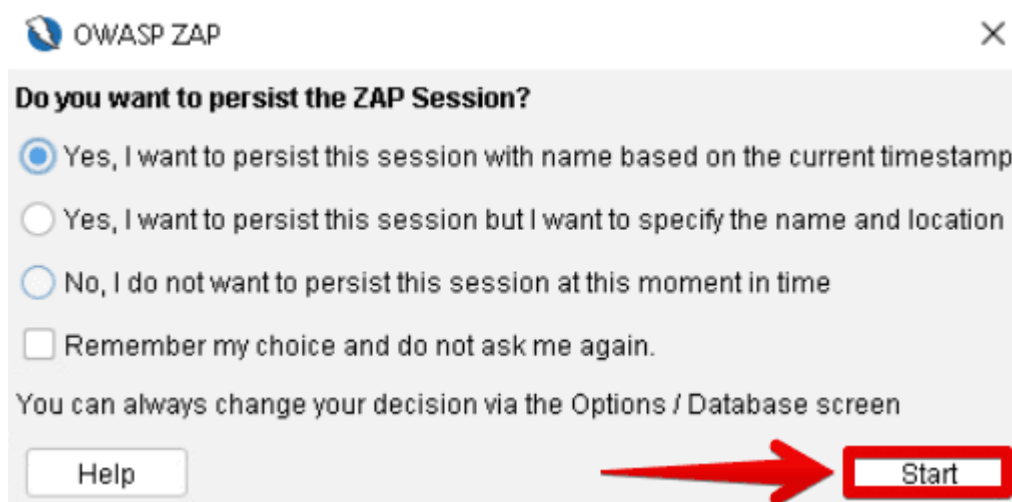
5

Click **Close** on **Internal Error** dialog box.



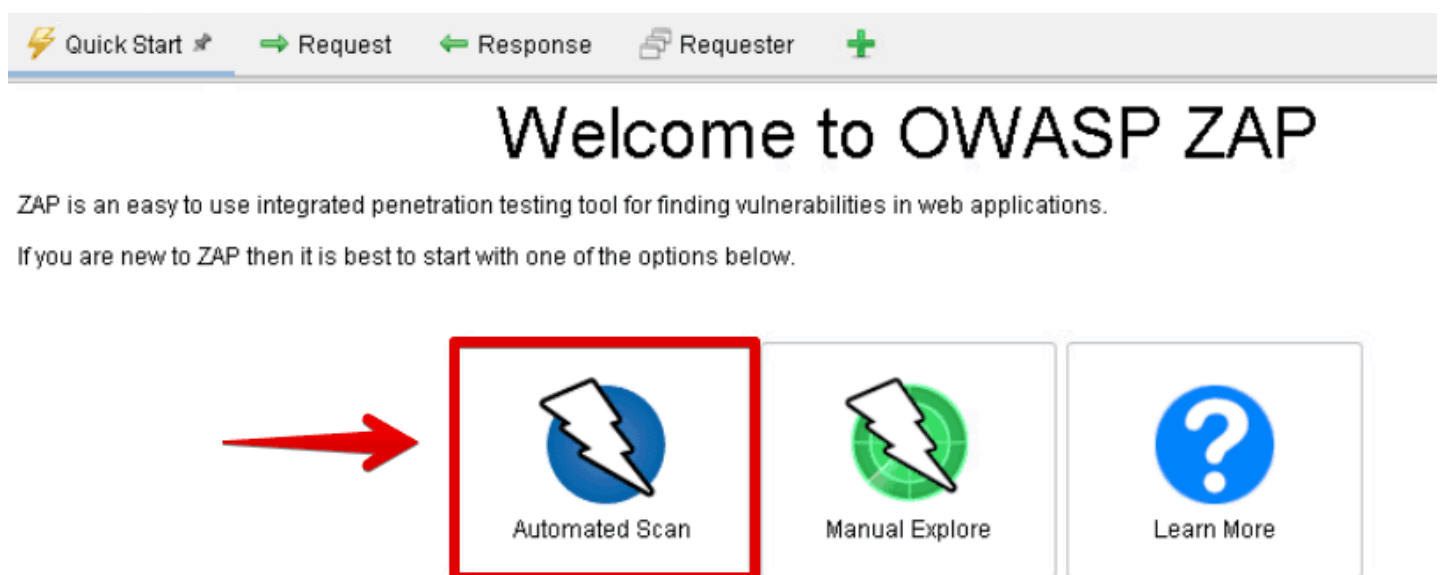
6

Click **Start** on the **OWASP ZAP** pop-up window.



7

Click **Automated Scan** in the **Welcome to OWASP ZAP** pane.





Note: The IP address of the ACIDM01 device is entered, this information was gathered from the previous exercise, and it was determined that the device might have vulnerabilities.

8 Tick the **Use ajax spider** tickbox and **select Chrome** in the **drop-down menu**.

The screenshot shows the 'Automated Scan' interface. At the top, there is a navigation bar with 'Quick Start', 'Request', 'Response', and 'Requester' tabs. Below this, the title 'Automated Scan' is displayed. A warning message states: 'This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.' The 'URL to attack' field contains 'http://'. Below this, the 'Use traditional spider' checkbox is checked. The 'Use ajax spider' checkbox is also checked and highlighted with a red box. To its right, a dropdown menu is open, showing options: 'Firefox Headless', 'Chrome' (highlighted with a red box and a red arrow), 'Chrome Headless', 'Firefox', 'Firefox Headless', 'HtmlUnit', and 'PhantomJS'. The 'Attack' button is visible below the dropdown. The 'Progress' status is 'Not started'.

9 In the **Automated Scan** pane, **enter** the **following** in the **URL to attack** field:

`http://192.168.0.2/xvwa`

Click **Attack**.

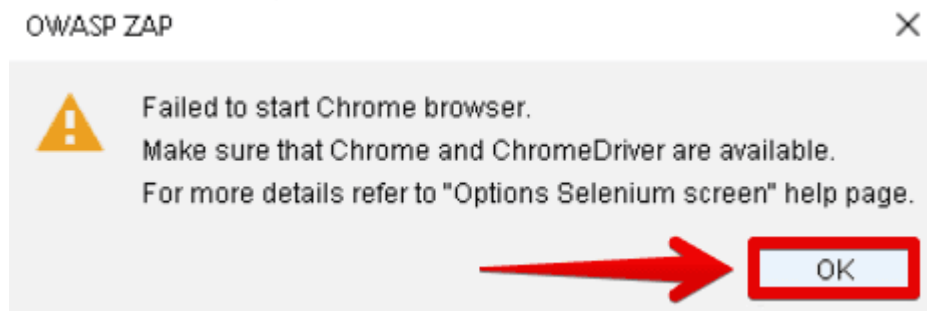
The screenshot shows the 'Automated Scan' interface with the URL 'http://192.168.0.2/xvwa' entered in the 'URL to attack' field. The 'Use traditional spider' checkbox is checked. The 'Use ajax spider' checkbox is checked, and the dropdown menu is set to 'Chrome'. The 'Attack' button is highlighted with a red box and a red arrow. The 'Progress' status is 'Not started'.



Note: The scan will take up to 10 minutes to complete. Let the scan run until the

Cross Site Scripting (Reflected) field displays.

- 10 If prompted, **click** the **OK button** in **OWASP ZAP dialog box**.



- 11 **Ensure** the **Alerts tab** is selected in the **bottom pane**.

- 12 **Select** **Cross Site Scripting (Reflected) (2)** in the **Alerts pane**.



Note: The ZAP application can detect vulnerabilities in a web application. A vulnerable web application has been implemented on the ACIDM01 device. Several vulnerabilities have been discovered, as can be seen in the output. A Cyber Security specialist can use these results to remediate the vulnerabilities to prevent an attack on the web application. Scroll through the detected vulnerabilities to get more information.

- 13 **Close** the **OWASP ZAP application**.

Task 2 – Detect Network Vulnerabilities using NMAP

The NMAP application can be used to scan a network device for vulnerabilities. Several different scripts are available when the application is installed.

In this task, the NMAP application will detect vulnerabilities on a network device.

- 1 **Connect** to **ACIALMA**, and **click Terminal** in the **Activities window**.



- 2 In the `aciadmin@localhost:~` window, **type** the following:

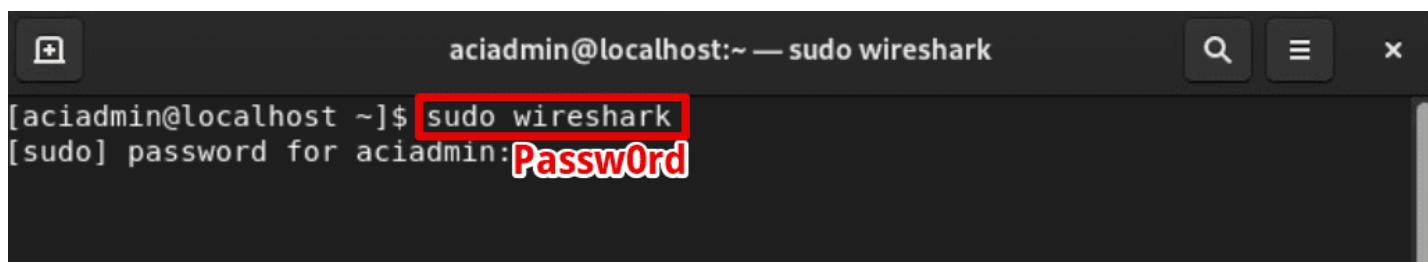
```
sudo wireshark
```

Press Enter.

In the `[sudo]` password for aciadmin, **enter** the following:

```
Passw0rd
```

Press Enter.



- 3 In the **Wireshark Network Analyzer** window, **ensure** `ens32` is selected and **click** **Start capturing packets**.

- 4 **Click** **Activities**, **right-click** **Terminal**, and **select** **New Window**.

- 5 In the `aciadmin@localhost:~` window, **type** the following:

```
ls -l /usr/share/nmap/scripts | more
```

Press Enter.

6 Using the **down arrow**, **scroll** through the different **NMAP scripts** available.



Note: The **Scripting Engine (NSE)** contains several scripts that a Cyber Security Specialist can use to detect vulnerabilities on devices on the network. To determine what these scripts' functions are, browse to the following site to get more information: [NSEDoc Reference Portal: NSE Scripts — Nmap Scripting Engine documentation](#)

7 In the **aciadmin@localhost:~** window, **type** the following:

```
nmap --script http-title -sV -p80 192.168.0.2
```

Press Enter.

8 In the **aciadmin@localhost:~** window, **type** the following:

```
nmap -script http-enum -sV -p80 192.168.0.2
```

Press Enter.



Note: Executing the command with the script displays information of the vulnerable website. From the results, it can be seen that there were two directories available that are publicly accessible. This may not be intentional and could pose a security risk that needs to be remediated.

9 **Click** **Activities** and **select** the **Wireshark** application.

10

In the **Capturing** from **eth0** window, **click** **Stop capturing packets**.

11

Enter the following in the **Apply a display filter** field:

http

Press Enter.



Note: The traffic between the devices was captured using the Wireshark application. A Cyber Security Specialist can analyze the captured traffic to detect vulnerabilities.

12

Scroll down through the **captured traffic**.

13

Close all of the **open windows**.

Task 3 – Scan Network Devices with Nessus

The Nessus application is used to scan network devices for vulnerabilities. A Cyber Security Specialist can use this application to detect and remediate vulnerabilities.

In this task, the Nessus application will be used to scan the network devices for vulnerabilities.

1

Ensure you are connected to **ACIALMA**, in **Activities**, **select Terminal**.

2

In the **aciadmin@localhost:~ terminal window**, **type** the **following** and **press Enter**:

```
sudo /opt/nessus/sbin/nessusd
```

When prompted, **enter** the **following password**:

Passw0rd

Press Enter.



Note: The executed command will start the necessary services and compile the needed plugins for the Nessus application. The process will take a couple of minutes to complete.

3

Click **Activities** and **select** **Firefox**.



Note: Do not close the terminal window to ensure the service will keep running.

4

In the **Firefox browser**, **browse** to the **following URL**:

`https://localhost:8834`

Click **Advanced**

5

If needed, **scroll down** and **select** **Accept the Risk and Continue**.

6

Select the **prepopulated credentials** on the **nessus Essential login page** and **click** **Sign In**.

7

Close the **Welcome to Nessus Essentials pop-up window**.

8

In the **My Scans pane**, **click** **Create a new scan**.

9

Click **Basic Network scan** on the **Scan Templates window**.

10

In the **Settings tab**, **complete** the **following**:

Name: `ACIPLAB`

Target: `192.168.0.0/24`

Click the **Credentials tab**.

11

Click **Windows** in the **Credentials** tab.

12

Complete the **following** on the **Windows Credentials** tab:

Username: **Administrator**

Password: **Passw0rd**

Domain: **aciplab.com**



Note: Using the ACIPLAB network credentials ensures the Nessus application will have sufficient permissions to scan the network devices on the network

13

Scroll down on the **New Scan / Basic Network Scan** pane, **click** the **down arrow** next to **Save** and **select Launch**.



Note: The scan will take 20 minutes to complete. Please wait for the scan to complete.

14

After the scan has been completed in the **My Scans** pane, **select ACIPLAB**.

15

Select the **Vulnerabilities** tab in the **ACIPLAB** pane.



Note: The number of detected vulnerabilities detected will vary depending on how long the scan has run.

16

Click the **Apache Http** vulnerability in the **Name** column.

17

Click the **CRITICAL** button on the **Sev** tab.

18

Click the **Hosts** tab on the **ACIPLAB** window.



Note: The Nessus application has detected several vulnerabilities on the scanned devices of the network. It can be seen that the version of the Apache server is vulnerable to exploitation.

19

Select **192.168.0.2** in the **Hosts** column.

20

Click **Back to Hosts** on the **ACIPLAB** pane.



Note: The Nessus application detected several vulnerabilities on the selected host. Note that the vulnerabilities have different Severity levels. A Cyber Security Analyst can use these results to remediate the detected vulnerabilities.

21

Click **192.168.0.3** on the **ACIPLAB** pane.



Note: The Nessus application detected several vulnerabilities on the selected host. The vulnerabilities detected need to be remediated by a Cyber Security Specialist to prevent device exploitation.

Task 4 – Detect Vulnerabilities using Metasploit and NMAP

The Metasploit application can be used with the NMAP application to detect vulnerabilities on network devices.

In this task, the Metasploit application will be used to determine network device vulnerabilities in conjunction with the NMAP application.

1

Connect to ACIKALI on the login screen, **enter** the following credentials, and **press**

Enter:

Username: aciadmin

Password: Passw0rd



Note: Please use Shift + P to enter the uppercase "P".

2

Click Terminal Emulator in the top pane.

3

In the aciadmin@ACIKALI@~ window, **type** the following and **press** Enter:

```
sudo msfdb init && msfconsole
```

4

When prompted, **enter** the following and **press** Enter:

```
Passw0rd
```

5

In the aciadmin@ACIKALI@~ window, **type** the following and **press** Enter:

```
use auxiliary/scanner/portscan/tcp
```

6

In the aciadmin@ACIKALI@~ window, **type** the following and **press** Enter:

```
show options
```



Note: The different options for scanning the devices on the network are displayed.

7 In the `aciadmin@ACIKALI@~` window, **type** the following and **press** Enter:

```
set RHOSTS 192.168.0.2
```



Note: A specific host or a range of hosts can be specified using the set RHOST command.

8 In the `aciadmin@ACIKALI@~` window, **type** the following and **press** Enter:

```
set PORTS 1-100
```



Note: A range of ports can be scanned on the remote host to determine if these ports are open.

9 In the `aciadmin@ACIKALI@~` window, **type** the following and **press** Enter:

```
exploit
```



Note: From the results, it can be determined that port 80 is open on the host.

10 In the `aciadmin@ACIKALI@~` window, **type** the following and **press** Enter:

```
db_nmap -sV -p 80 192.168.0.2
```

11 **Close** the `aciadmin@ACIKALI@~` window after viewing the output of the command.



Note: The version of the Apache server is displayed after running the scan using NMAP and Metasploit. A Cyber Security Specialist can search to find out if there are any vulnerabilities for the version of the Apache server.

Review

Well done, you have completed the [Vulnerability Scanning Tools & Techniques](#) practice lab.

Summary

You completed the following exercises:

- Exercise 1 – Network Asset Detection Tools
- Exercise 2 – Detecting Network Vulnerabilities

You should now be able to:

- Use NMAP to Detect Devices on the Network.
- Use Zenmap to Discover Devices on the Network.
- Scan Network Devices for Vulnerabilities with OWASP Zap.
- Detect Network Vulnerabilities using NMAP.
- Scan Network Devices with Nessus.
- Detect Vulnerabilities using Metasploit and NMAP .

Feedback



Shutdown all virtual machines used in this lab. Alternatively, you can log out of the

lab platform.